ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Siemens DIGSI 5 (SIPROTEC 5 engineering software) · Component type: **Software Application (SAR) - protection-relay engineering software** · Target SL = SL 3

Where to work	**DIGSI 5** on a Windows host: **Tools › Manage certificate authorities (CA)** (the DIGSI 5 CA store); the **customer client certificate** installed in the Windows user account; per-device **Safety and security** config (connection password, RBAC, Network access security - see the relay sheet); the **DIGSI 5 project** (holds all device configs). PKI issued via **SICAM GridPass**. Installer from Siemens (signed).
Ports / paths	DIGSI 5 connects to SIPROTEC 5 relays over a mutually-authenticated **TLS** channel (client certificate) and **IEC 61850 MMS TCP 102 / SecureTLS 3782**; the DIGSI 5 **project** + CA store live on the host - protect them. Runs on Windows; harden the host and patch DIGSI 5 (CISA ICSA-26-174-02 DIGSI5 protocol).
Notes	SAR - Siemens DIGSI 5 (SIPROTEC 5 engineering software). Its distinctive control is **DIGSI 5 client authentication** - install the customer CA in the device (relay) and a customer-signed client certificate in each authorized DIGSI 5 Windows account, so unauthorized DIGSI installations cannot connect. Assess the relay itself on the 7SJ85 / 7UM85 sheets. Confirm the DIGSI 5 version and patch level.
How to read	Each row = native step-by-step (DIGSI 5 / host) + command-level external-tool steps. Default read-only. Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the DIGSI 5 project archive (.dz5), per-device configuration/settings exports (.dex5), the connection passwords / confirmation-code and role settings, and the logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm DIGSI 5 access is layered: (1) the host **Windows account** controls who may run DIGSI 5 and holds the **customer client certificate**; (2) connecting to a relay requires that certificate **plus** the device **connection password** / RBAC login. Only DIGSI 5 installations with a customer-CA-signed certificate can connect (default Siemens cert should be replaced). **Test:** from a DIGSI 5 install without a customer-signed client cert, connect to a relay -> refused; without the connection password -> refused. **Ext. tools:** DIGSI 5 (Tools › Manage CA - customer CA present); host (who may run DIGSI 5); attempt connect w/o cert/password -> refused.	Client-certificate + connection password/RBAC required; default cert replaced; host restricts execution.	
SR/CR 1.2	Software process / device identification	Confirm each relay is uniquely identified in the DIGSI 5 project (IEC 61850 IED name, IP per module, type/serial) and DIGSI 5 addresses only intended devices; TLS binds the device by certificate. **Ext. tools:** DIGSI 5 (IED name / device list); `openssl s_client -connect <relay>:3782`; Wireshark `tls || mms`.	Unique, certificate-bound device identities; no rogue devices.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.3	Account management	Manage: (a) the host/AD accounts allowed to run DIGSI 5 (least privilege); (b) which DIGSI 5 installations are trusted (customer-CA-signed client certs - revoke lost ones via the CA); (c) the relay RBAC/central users (RADIUS/LDAP, per the relay sheet). No shared client certs/passwords. **Ext. tools:** Host/AD accounts; SICAM GridPass / CA (issued/revoked client certs); relay RBAC review.	Host, DIGSI-trust, and relay accounts managed/least-privilege; lost certs revocable.	
SR/CR 1.4	Identifier management	Confirm unique host user IDs, unique DIGSI 5 client-certificate identities, and unique relay identities; no reuse. **Ext. tools:** Host/AD; CA (cert subjects); DIGSI 5 device list.	Unique user, certificate, and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Client certificates use strong keys (managed by the customer CA / GridPass); the device connection password is 8-24 chars (NERC-CIP format) - confirm strong and non-default; host/AD password policy for the DIGSI 5 login. Rotate/expire per policy. **Ext. tools:** SICAM GridPass (key/cert policy); relay connection-password (per relay sheet); host/AD policy.	Strong certificate keys + connection password; defaults changed; managed lifecycle.	
SR 1.6	Wireless access management	**N/A.** Engineering software with no wireless interface. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	This is central to DIGSI 5: confirm the **customer CA** is provisioned (SICAM GridPass), the DIGSI 5 **CA store** trusts it, client certs are CA-signed/valid with strong keys, and the default "SIPROTEC 5 trusted certificate authority" is replaced. Verify the configured CA via a browser as the manual describes. **Ext. tools:** DIGSI 5 (CA store / Trusted CA); SICAM GridPass (issuance); `openssl x509 -noout -issuer -dates` on the client/device certs.	Customer CA provisioned + trusted; client/device certs CA-signed, strong, valid; default replaced.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm DIGSI 5 masks the connection-password entry (shown as asterisks, entered twice) and any host login. **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The relay records wrong connection passwords and responds after 5 attempts (per the relay sheet); with central RBAC, lockout is upstream. DIGSI 5-to-relay auth is cert-gated (a wrong install cannot even connect). Host/AD lockout for the DIGSI login. **Ext. tools:** Relay security log (per relay sheet); host/AD lockout; SIEM failed-auth.	Cert-gated connection; relay/host lockout; failures logged.	
SR/CR 1.12	System use notification	No DIGSI 5 banner; enforce the approved use notice on the engineering-workstation host (GPO). **Ext. tools:** Host `gpresult /h gp.html`.	Use notice at the host (compensating).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the DIGSI 5 host + relays are in the trusted substation zone; remote engineering via VPN/jump host; MMS/DIGSI not exposed to untrusted networks. **Ext. tools:** `nmap -Pn -p 102,3782 <relay>` from the untrusted side (expect filtered); firewall review.	Engineering access from untrusted networks denied; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Authorization is enforced at the relay (RBAC access levels no/read-only/full + confirmation IDs) - confirm a read-only DIGSI 5 user cannot change settings or operate; and at the host (only authorized users run DIGSI 5). **Test:** as a read-only relay user in DIGSI 5, attempt a setting change / control -> denied. **Ext. tools:** DIGSI 5 (per-interface access levels; confirmation IDs); read-only negative test (isolated).	Least privilege at the relay; host restricts execution; privileged actions denied.	Delegated to relay.
SR/CR 2.2	Wireless use control	**N/A.** Software, no wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded.	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR 2.3	Use control for portable/mobile devices	Control the DIGSI 5 laptop and removable media (OS device-control) and the relay front USB; only authorized DIGSI 5 projects/firmware loaded; the client cert is bound to the Windows user account. **Ext. tools:** Host removable-media GPO; confirm the client cert is per-user (not portable).	Portable/engineering media controlled; client cert bound to the user account.	
SR/SAR 2.4	Mobile code	No general-purpose mobile code; confirm only the signed DIGSI 5 runs and no untrusted add-ons/CFC libraries execute; CFC logic is reviewed. **Ext. tools:** Installed-component review; verify installer signature; CFC review.	Only signed/required components; no untrusted code.	SAR-specific.
SR/CR 2.5	Session lock	Confirm the host OS screen lock on inactivity; DIGSI 5 / relay re-authenticate after lock. **Ext. tools:** Host inactivity-lock GPO.	Host locks on inactivity; re-auth required.	Compensating.
SR/CR 2.6	Remote session termination	Confirm DIGSI 5-to-relay sessions can be ended and idle sessions close; the relay bounds concurrent connections so simultaneous conflicting configuration is prevented. **Ext. tools:** DIGSI 5 connection review; Wireshark (session teardown).	Sessions terminable; concurrency bounded at the relay.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm engineering actions are attributable: the relay **security log** (per-user under RBAC) records setting/firmware/switching changes and is forwarded via **Syslog** to the SIEM; DIGSI 5 project change tracking records who changed configs. Forward to the SIEM. **Test:** download a setting change -> a relay security-log/Syslog event with the user + time. **Ext. tools:** DIGSI 5 (project change history); relay Syslog (`nc -lu 514`) + SIEM.	Changes attributable (RBAC + project history); relay events forwarded to the SIEM.	
SR/CR 2.9	Audit storage capacity	Confirm relay Syslog + DIGSI 5 project history are offloaded/retained (SIEM) with alerting on collection failure. **Ext. tools:** SIEM retention + source-silent alert.	Logs offloaded/retained; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the host + relays are time-synced (SNTP/PTP/IRIG-B at the relay) so audit timestamps correlate. **Ext. tools:** `w32tm /query /status`; relay time source (per relay sheet).	Accurate, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	DIGSI 5-to-relay comms are mutually-authenticated **TLS** (client + device certs); confirm Secure MMS (SecureTLS 3782) is used and the non-secure 102 path is disabled at the relay. No cleartext engineering traffic. **Ext. tools:** Wireshark `tls || mms` (encrypted DIGSI/MMS; no cleartext 102); `nmap -p 102,3782 <relay>`.	DIGSI/MMS on mutually-authenticated TLS; non-secure path disabled.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only the Siemens-**signed** DIGSI 5 (verify the installer signature / download from Siemens); host anti-malware; restrict install/upgrade to admins; patch per CISA ICSA-26-174-02. **Ext. tools:** `signtool verify /pa <setup>.exe`; host AV; installed-version vs patched.	Signed software validated; install restricted; AV active; patched.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: customer CA in the DIGSI 5 CA store, client-cert trust, connection password/RBAC, Secure MMS, and patch level, against the C081 baseline; compare the DIGSI 5 project. **Ext. tools:** DIGSI 5 (CA store + project compare); `nmap -p 102,3782 <relay>`.	Security settings match the C081 hardening baseline after change.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.4	Software & information integrity	Protect the DIGSI 5 project (device configs, and where applicable certificates): host ACLs, encrypt at rest (BitLocker), version + change-track; use DIGSI 5 project compare to detect drift. **Ext. tools:** Host ACL on the project; DIGSI 5 project compare; `certutil -hashfile <project> SHA256`.	Project protected + change-tracked; integrity baselined.	
SR/CR 3.5	Input validation	Patch known DIGSI 5 / DIGSI5-protocol CVEs (CISA ICSA-26-174-02) and confirm DIGSI 5 handles malformed device responses without crashing. **ISOLATED:** test against a bench relay. **Ext. tools:** Nessus/OpenVAS on the host; Siemens ProductCERT cross-check; ISOLATED malformed-response test.	Known CVEs patched; malformed input handled safely.	
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm errors are handled gracefully without leaking sensitive info (no plaintext passwords/keys in DIGSI 5 logs/crash dumps). **Ext. tools:** DIGSI 5 / host event-log review.	Graceful error handling; no secret leak.	
SR/CR 3.8	Session integrity	DIGSI 5-to-relay TLS sessions are integrity-protected (mutual auth) against replay/hijack; no unauthenticated engineering path remains (102 disabled). **Ext. tools:** Wireshark (TLS session; no cleartext MMS).	Sessions integrity-protected; no unauthenticated path.	
SR/CR 3.9	Protection of audit information	Protect the relay Syslog transport + SIEM store and the DIGSI 5 project history; restrict who can read/clear them (host ACLs + relay rights). **Ext. tools:** SIEM access review; host ACL; relay log-access rights.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose of the host, remove the DIGSI 5 project, the client certificate + private key, the CA store, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** Remove client cert/key (certmgr); confirm project/backups removed; BitLocker status.	Project, certificates, and keys purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto: DIGSI/MMS TLS with strong suites, CA-signed certs, strong keys; the project protected at rest (host encryption). **Ext. tools:** `testssl.sh`-style check on the MMS/DIGSI TLS (or openssl); confirm host disk encryption.	Modern TLS + managed certs; project encrypted at rest.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the DIGSI 5 host + relays sit in a segmented substation/OT zone behind a firewall; only required MMS/DIGSI flows cross; remote engineering via a jump host; no flat convergence with IT. **Ext. tools:** `nmap -p 102,3782 <relay>` per zone; firewall rule review.	Host + relays in a segmented zone; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Engineering software with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: separate DIGSI 5 projects / CA scopes per substation/zone and least-privilege host access; do not co-mingle unrelated criticality. **Ext. tools:** DIGSI 5 project/CA segregation; host access review.	Projects/CA scopes partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm relay security logs (via DIGSI 5) and the DIGSI 5 project history are readable/exportable by authorized staff and forwarded (Syslog) to the SIEM; passive OT IDS on the substation LAN. **Ext. tools:** DIGSI 5 export; relay Syslog + SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial of service protection	The engineering tool is not a runtime service; confirm the host is resourced/hardened and relay connections are bounded so a flood cannot deny engineering access; do not co-host unrelated apps. **Ext. tools:** Host resource monitor; relay connection-limit review.	Host/connection resources bounded; engineering access available.	
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Confirm the DIGSI 5 project, client certificate/key, and CA config are backed up (versioned, offline) and a restore/rebuild is tested (re-issue certs from GridPass if needed). **Ext. tools:** Backup repository; restore + validate on a lab host/relay.	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: replace the default Siemens cert with a customer-CA client cert, run DIGSI 5 on a hardened least-privilege host, install only DIGSI 5, keep it patched (CISA advisory), and remove sample projects. **Ext. tools:** DIGSI 5 CA/cert config; host hardening review; version vs patched.	Least functionality; customer-CA trust; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the DIGSI 5 version, installed drivers/add-ons, and the OS so vulnerabilities track against Siemens ProductCERT / CISA advisories (e.g. ICSA-26-174-02). **Ext. tools:** DIGSI 5 About / installed components; Siemens ProductCERT feed.	Accurate version/component inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
DIGSI 5	Native PKI/RBAC & project review (all FRs)	Tools › Manage certificate authorities (CA); per-device Safety and security (connection password, RBAC, Secure MMS); project change history. Assess the relay on its sheet. Back up the project + certs.	Read/authorized project copy.
SICAM GridPass (PKI)	Customer CA & client/device certs (1.8, 3.13-equiv)	Issue/sign/revoke DIGSI 5 client certificates and device certificates from the customer CA; verify the configured CA via a browser.	PKI ops.
signtool	Signed-installer validation (SAR 3.2)	`signtool verify /pa <setup>.exe` or Properties › Digital Signatures; download from Siemens.	Read-only.
openssl	Client/device cert & TLS inspection (1.2, 1.8, 4.3)	`openssl s_client -connect <relay>:3782 | openssl x509 -noout -issuer -dates`; confirm CA-signed, strong, valid.	Read-only.
nmap	Relay/service exposure & segmentation (1.13, 3.1, 5.x)	`nmap -p 102,3782 <relay>`; scan per zone; confirm 102 closed and only required reachable.	Read-only; authorized.
Wireshark	Comms integrity & session (3.1, 3.8)	Filter `tls || mms`; confirm mutually-authenticated TLS on DIGSI/MMS and no cleartext 102.	Passive; SPAN/tap only.
Nessus / OpenVAS + Siemens ProductCERT	CVE scan (3.5, 7.8) incl. ICSA-26-174-02	Scan the engineering host for known DIGSI 5 CVEs; cross-check Siemens ProductCERT / CISA advisories.	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.